Proyecto · Parte 1
Diseño del control de acceso

Políticas, matriz y arquitectura de seguridad

Duración: 4 semanas · Entrega: jueves 15 de octubre · Grupos de 4 a 5 estudiantes · **20 % de la nota**

Atributo de acreditación evaluado: **Diseño (DI)**

En una frase. Una empresa los contrató para diseñar el control de acceso de su plataforma. **Aquí no se programa**: se entrega la decisión de diseño, documentada y defendible.

1 Objetivo

General. Diseñar el control de acceso y la arquitectura de seguridad de un sistema real, decidiendo **quién puede hacer qué, bajo qué condiciones y con qué tecnología**, y dejando cada decisión documentada de forma que otro equipo pueda implementarla sin preguntarles nada.

1.1 Como consultor de seguridad — análisis y política

- Identificar los activos de información del cliente y clasificarlos por sensibilidad.
- Construir un modelo de amenazas que contemple tanto al atacante externo como al **empleado con credenciales legítimas**.
- Determinar qué obligaciones legales aplican al giro del negocio y traducirlas en reglas operativas.
- Redactar políticas que describan **a este cliente**, no a una empresa genérica.

1.2 Como arquitecto de seguridad — diseño y decisión

- Escoger un modelo de control de acceso entre DAC, MAC, RBAC y ABAC, y **defender la elección frente a los otros tres**.
- Decidir qué controles basados en historial (HBAC) requiere el sistema y de qué tipo.
- Seleccionar una técnica de separación de responsabilidades y aplicarla sobre una acción crítica concreta.
- Expresar todo lo anterior en una **matriz de control de acceso** verificable celda por celda.
- Definir con qué tecnologías se construirá el sistema, justificando cada elección **desde la seguridad**.

2 Carta de encargo del cliente

Lo que sigue es el encargo tal como lo entrega la empresa. Es el mismo para todos los equipos, y es el único insumo del que sale el diseño.

VERDEAZUL CARBONO S.A.
Certificación de captura de carbono · Pérez Zeledón, Costa Rica

San Isidro de El General, 8 de setiembre de 2026

Estimados señores:

Nos dirigimos a ustedes para contratar el **diseño del control de acceso** de la plataforma que vamos a construir el próximo año. Les explico primero a qué nos dedicamos, porque de ahí sale casi todo lo que necesitamos.

Verdeazul certifica captura de carbono en fincas forestales del país. Un técnico nuestro visita la finca, mide el crecimiento de la biomasa y registra los datos; un verificador revisa esa medición y, si la aprueba, se emite un **certificado de carbono** que el dueño de la finca vende en mercados internacionales. Cada certificado vale dinero real y respalda una tonelada de carbono que alguien, en algún lugar, está dejando de compensar por otra vía.

Eso significa que **un dato inflado es fraude**, y que respondemos ante auditores europeos que pueden pedirnos la trazabilidad completa de cualquier certificado emitido en los últimos diez años. Hoy llevamos todo en hojas de cálculo compartidas y ya tuvimos dos sustos: una medición que alguien modificó después de aprobada sin que sepamos quién, y un certificado que se emitió dos veces sobre la misma hectárea.

Quiénes trabajan con esto. No sé cómo se organiza eso en un sistema, así que les cuento cómo trabajamos nosotros y ustedes nos dicen.

Hay gente que **sale a campo**: llega a la finca, toma las mediciones y las registra. Son los que más entran al sistema y los que menos tiempo tienen para pelearse con él. Otra gente **revisa ese trabajo desde la oficina** y decide si la medición se aprueba o se devuelve; de ellos depende que un certificado se emita o no. Tengo también a quien **administra el catálogo de fincas** y da de alta a la gente nueva cuando entra a la empresa.

Aparte están los **auditores externos**, que vienen una vez al año, necesitan ver absolutamente todo y no deberían poder tocar nada. Y los **dueños de las fincas**, que solo deberían ver lo suyo —sus mediciones, sus certificados— y nada de los demás. Eso último nos importa: son competencia entre ellos.

Lo que quisiéramos saber del sistema. Si alguien cambió un dato, quién fue y cuándo. Si un certificado se emitió, quién lo aprobó. Y si alguien anduvo viendo información que no le correspondía, aunque tuviera permiso de verla.

Cómo trabajamos. Las mediciones se hacen por **períodos**: abrimos un período de medición, los técnicos registran durante esas semanas, y cuando cierra ya nadie debería poder cambiar nada. Si de verdad hay que corregir algo después, queremos que quede como una enmienda registrada, no como una edición silenciosa.

Nos preocupa además que la misma persona pueda medir y aprobar. No es que desconfiemos de nuestra gente, pero los auditores nos lo van a preguntar y preferimos tener la respuesta antes.

Un detalle que nos incomoda. El año pasado un técnico consultó cientos de fincas que no le correspondían durante un fin de semana. Tenía el permiso para verlas, así que técnicamente no hizo nada malo. Renunció al mes siguiente y se fue a la competencia. No sabemos qué hacer con eso, pero nos gustaría que el sistema al menos se diera cuenta.

Lo que necesitamos de ustedes. El diseño completo: las políticas, quién puede hacer qué, y con qué tecnología lo construiríamos. Tenemos presupuesto para software libre únicamente. Y necesitamos poder explicarle a un auditor por qué el sistema está diseñado así.

Quedo atento a sus consultas.

Marcela Quesada Ureña
Gerente de Certificación · Verdeazul Carbono S.A.

2.1 Cómo leer la carta

La carta está redactada como la escribiría un cliente real: dice a qué se dedica la empresa y qué le preocupa, pero **no dice qué modelo de control de acceso usar ni qué reglas escribir**. Eso es lo que ustedes tienen que decidir y defender.

Hay además cosas que la carta deja abiertas a propósito. Por ejemplo: no aclara si un verificador puede también registrar mediciones, ni qué pasa exactamente con el técnico del último párrafo, ni quién autoriza una enmienda después del cierre.

2.2 Cómo consultar al cliente

Las dudas sobre el encargo no se resuelven en pasillo. El equipo **coordina formalmente una cita** con la parte interesada —el profesor, en el papel de Verdeazul— por correo electrónico:

```
Para:     a.vargas@itcr.ac.cr
Asunto:   CE1115 - Grupo # - Consultas VERDEAZUL CARBONO S.A
```

- En el correo se indica **qué se quiere consultar** y se proponen horarios.
- A la cita se llega con las preguntas escritas: no es una sesión para pensar en voz alta.
- Lo que se responda en la reunión **queda en minuta** y pasa a formar parte del enunciado para ese equipo.
- La minuta la redacta el equipo y se adjunta como anexo del informe de políticas.

Alcance de este proyecto. Aquí **no se escribe código**. Se evalúa el criterio de diseño y la calidad de la documentación: un diseño tan claro que otro equipo pueda construirlo sin consultarles nada.

3 Entregables

Son cinco documentos y una defensa oral. **Todos los documentos se redactan en LaTeX** y se entregan en fuente y PDF (ver la sección de formato y entrega).

#	Entregable	Pregunta que responde
1	Informe de políticas de seguridad	¿Qué protegemos y bajo qué reglas?
2	Documento de control de acceso	¿Quién puede hacer qué, y bajo qué condiciones?
3	Matriz o matrices de control de acceso	¿Dónde está eso escrito de forma verificable?
4	Documento de arquitectura del sistema	¿Con qué lo vamos a construir y por qué?
5	Documento del atributo Diseño (DI)	¿Dónde está la evidencia de que diseñaron?
6	Defensa oral	¿Puede el equipo sostener sus decisiones?

4 Entregable 1 · Informe de políticas de seguridad

Documento dirigido a la gerencia del cliente. No es un manual técnico: es el marco que después justifica cada decisión de control de acceso y de arquitectura.

4.1 Qué debe contener

- **Alcance y activos.** Qué protege la política y qué información maneja la empresa, clasificada por sensibilidad.
- **La tríada aplicada al negocio.** Qué significan confidencialidad, integridad y disponibilidad *en esta empresa*, cuál de las tres pesa más y por qué.
- **Modelo de amenazas.** Quién querría atacar el sistema, con qué motivo y qué podría lograr. Debe incluir al menos **una amenaza interna**.
- **Marco regulatorio.** Qué obligaciones legales aplican al giro del cliente. Como mínimo la **Ley 8968** de Protección de la Persona frente al Tratamiento de sus Datos Personales.
- **Políticas de cuentas y accesos.** Alta, baja y cambio de puesto; revisión periódica de permisos; qué se registra en bitácora y por cuánto tiempo.
- **Política de contraseñas y autenticación**, coherente con lo visto en clase.

Extensión: 8 a 12 páginas de contenido, sin contar portada, índice ni anexos.

5 Entregable 2 · Documento de control de acceso

El documento central de esta entrega. Aquí se decide y se justifica el modelo, los controles de historial y la técnica de separación de responsabilidades.

5.1 Modelo de control de acceso elegido

El equipo debe **escoger explícitamente** uno de los cuatro modelos vistos en clase, o una combinación justificada de ellos, y defender la elección frente a los otros tres.

Modelo	En qué basa la decisión	Cuándo conviene
DAC	El dueño del recurso decide quién accede	Compartición flexible entre usuarios; poco control central
MAC	Etiquetas de clasificación que impone el sistema	Niveles de confidencialidad rígidos que el usuario no puede alterar
RBAC	El rol organizacional del sujeto	Estructura de puestos estable; entrada y salida frecuente de personal
ABAC	Atributos del sujeto, del objeto y del entorno	Reglas que dependen del contexto y combinaciones difíciles de enumerar

Lo que hay que argumentar

1. **Cuál eligieron** y qué característica del negocio del cliente lo hace apropiado.
2. **Por qué no cada uno de los otros tres.** Una razón concreta por modelo descartado, ligada al caso.
3. **Si es híbrido, dónde está la frontera:** qué decisiones resuelve cada modelo y cómo se combinan sin contradecirse.
4. **Qué nivel de RBAC usarían**, si eligieron RBAC: plano (RBAC0), jerárquico (RBAC1), con restricciones (RBAC2) o ambos (RBAC3), según Sandhu *et al.* (1996).
5. **Riesgo de explosión de roles** y cómo lo evitan, si aplica.

5.2 Controles basados en historial (HBAC)

El equipo debe indicar **si va a implementar controles basados en historial y cuáles**. Por cada control, especificar:

- **Qué tipo de regla es:** por secuencia (qué hizo antes), por frecuencia (cuántas veces), por tiempo (cuándo) o combinada.
- **Qué riesgo concreto mitiga.** Debe conectar con una amenaza del modelo del Entregable 1.
- **Qué información hay que conservar** para evaluar la regla, y por cuánto tiempo.
- **Qué decide el motor:** conceder, denegar, o conceder con restricciones —por ejemplo exigir un segundo factor o la aprobación de un supervisor—.
- **Qué falsos positivos espera** y qué pasa con el usuario legítimo que los dispara.

Mínimo exigido: dos controles de tipos distintos, o una justificación escrita de por qué el caso no los requiere.

5.3 Técnica de separación de responsabilidades

El equipo debe **nombrar** la técnica que va a usar, **justificarla** frente a las alternativas y mostrar **dónde exactamente** la aplica en su matriz.

Cuál usar es parte de la investigación del proyecto. Estas son algunas de las técnicas que existen; el equipo debe averiguar cómo funciona cada una, si hay otras que apliquen mejor a su caso, y sustentar la elección con fuentes.

Técnica	Punto de partida
Roles mutuamente excluyentes	Un usuario no puede tener a la vez dos roles en conflicto. Investiguen la restricción de RBAC2 en Sandhu *et al.* (1996) y la diferencia entre exclusión estática y dinámica.
Doble control (cuatro ojos)	La acción requiere que dos personas distintas la confirmen. Vean cómo se aplica en banca y en sistemas de despliegue.
Separación por etapas del flujo	Quien inicia el proceso no puede cerrarlo. Revisen cómo lo tratan los marcos de control interno.
Segregación temporal	El permiso se otorga por una ventana limitada y vence solo. Busquen acceso «justo a tiempo» en soluciones de gestión de accesos privilegiados.
Rotación de responsabilidades	Quien ocupa una posición sensible cambia periódicamente, de modo que un fraude sostenido requiera complicidad.

Qué debe responder la sección

1. **Qué acción crítica** del sistema no debe poder completar una sola persona, y qué pasaría si pudiera.
2. **Qué técnica escogieron** y por qué es la adecuada para ese riesgo.
3. **Qué alternativas descartaron** y con qué razón. El costo operativo cuenta como razón válida.

4. **Cómo se refleja en la matriz:** qué celdas cambian, qué roles se vuelven mutuamente excluyentes, qué condiciones aparecen.
5. **Qué fricción introduce** y cómo la manejarían.

Extensión del Entregable 2: 8 a 12 páginas de contenido.

6 Entregable 3 · Matriz de control de acceso

El artefacto más verificable de la entrega: es donde el diseño deja de ser prosa y se vuelve comprobable. Sujetos en las filas, objetos en las columnas, y en cada celda los permisos concretos.

6.1 Requisitos

- **Todos los roles y todos los objetos.** Nada implícito: si un rol no puede tocar un objeto, la celda lo dice.
- **Permisos explícitos** por celda: leer, crear, modificar, eliminar, aprobar, o los que correspondan al dominio.
- **Al menos tres celdas condicionadas**, donde el permiso depende del estado del sistema o del historial del sujeto y no solo del rol. Cada condición se escribe como regla verificable.
- **Justificación de mínimo privilegio:** por cada permiso amplio, una línea que explique por qué no puede ser más estrecho.

7 Entregable 4 · Documento de arquitectura del sistema

Dirigido al equipo que va a construir el sistema. Describe **cómo** se va a construir y **con qué**, justificando siempre desde la seguridad.

7.1 Arquitectura general

- **Diagrama de componentes:** qué piezas tiene el sistema y cómo se comunican.
- **Frontera de confianza:** qué componentes se consideran confiables y cuáles no, y dónde se valida la entrada que cruza cada frontera.
- **Flujo de una petición autenticada**, desde que llega hasta que se concede o se deniega, indicando **en qué punto** se toma la decisión de autorización.

7.2 Selección de tecnologías

Por cada decisión —lenguaje, framework, base de datos, mecanismo de sesión, motor de autorización, contenedores— el documento debe indicar:

1. **Qué se eligió** y en qué versión.
2. **Qué alternativas se consideraron** y por qué se descartaron.
3. **Qué aporta a la seguridad:** qué mecanismos de protección ofrece de forma nativa. Por ejemplo, si el framework previene inyección con consultas parametrizadas, o si el motor de plantillas escapa la salida por omisión.
4. **Qué limitaciones de seguridad tiene** y cómo se compensan.
5. **Qué herramientas de análisis existen** para ese stack.

7.3 Decisiones de seguridad de la implementación

- **Dónde vive la decisión de autorización.** Qué pasa si el control está solo en la interfaz.
- **Cómo se implementan las celdas condicionadas:** qué información hay que almacenar para evaluar cada regla y en qué momento del flujo se evalúa.
- **Almacenamiento de credenciales:** qué mecanismo y por qué.
- **Gestión de sesión:** cómo se identifica al usuario entre peticiones, y qué pasa al cerrar sesión o al cambiar de privilegios.
- **Diseño de la bitácora:** qué eventos se registran, con qué campos, y cómo se protege de ser alterada por quien tiene permiso de escritura.
- **Gestión de secretos:** dónde viven las llaves y contraseñas de servicio, y por qué no en el código.
- **Riesgos residuales:** qué queda sin cubrir y por qué se acepta.

Esconder un botón no es autorización. Si el único control es que la interfaz no muestre la opción, cualquiera que llame directamente al servidor la ejecuta. Es el problema de referencias directas a objetos que vieron en clase 13, y **el primer ataque** que cualquiera va a intentar.

Extensión del Entregable 4: 8 a 12 páginas de contenido, sin contar diagramas en anexo.

8 Entregable 5 · Atributo de acreditación

La carrera está acreditada y eso obliga a evidenciar, con trabajo real del estudiantado, el logro de ciertos atributos definidos por el TEC. Este proyecto evidencia el atributo **Diseño (DI)**, porque es exactamente lo que hacen aquí: identificar requerimientos, valorar alternativas y diseñar una solución.

Se entrega un PDF aparte de los demás documentos, corto, donde el equipo responde con ejemplos concretos del proyecto.

8.1 Texto oficial del atributo

Definición. Diseña soluciones creativas para problemas de ingeniería complejos y diseña sistemas, componentes o procesos para satisfacer las necesidades identificadas con la consideración adecuada para la salud y la seguridad públicas, el costo total de la vida, el carbono neto cero, así como las consideraciones de recursos, culturales, sociales y ambientales según sea necesario.

Ind.	Texto oficial del indicador
DI1	Identifica las necesidades y los requerimientos de un problema complejo de ingeniería considerando la salud y la seguridad pública, el costo total de la vida, el carbono neto cero, así como aspectos relacionados con recursos, culturales, sociales y ambientales según sea necesario.
DI2	Valora alternativas de solución para un problema complejo de ingeniería que cumplan con necesidades específicas, considerando los mismos aspectos.
DI3	Diseña de forma creativa, la alternativa seleccionada que cumpla con las necesidades específicas para resolver el problema complejo de ingeniería, considerando los mismos aspectos.

DI4	Valida el diseño final de acuerdo con los requerimientos, la salud y la seguridad pública, el costo total de la vida, el carbono neto cero, así como aspectos relacionados con recursos, culturales, sociales y ambientales según sea necesario.

8.2 Qué debe responder el equipo

Bajo cada indicador, copiado literalmente, el equipo redacta su respuesta apoyándose en estas preguntas guía.

Ind.	Preguntas guía
DI1	¿Qué requerimientos extrajeron de la carta de encargo, y cuáles tuvieron que deducir o consultar? ¿Qué aspectos de seguridad de las personas, legales o del negocio de Verdeazul condicionaron el diseño?
DI2	¿Qué alternativas valoraron en el modelo de control de acceso, en los controles de historial y en la técnica de separación de responsabilidades? ¿Con qué criterio compararon, y qué costo tenía cada opción descartada?
DI3	¿Cómo se refleja la alternativa elegida en la matriz y en la arquitectura? ¿Qué decisión de diseño consideran propia del equipo y no una aplicación mecánica de lo visto en clase?
DI4	¿Cómo comprobaron que el diseño responde a lo que pedía el cliente? ¿Qué requerimiento quedó sin cubrir y por qué se aceptó ese riesgo residual?

9 Defensa oral

Cada equipo presenta y defiende su diseño ante el profesor. La presentación debe recorrer **todas las etapas del trabajo**: el cliente y sus activos, el modelo de amenazas, el modelo de control de acceso elegido, los controles de historial, la técnica de separación de responsabilidades, un recorrido por la matriz y las decisiones de arquitectura.

- **Participan todos los integrantes.** El reparto lo decide el equipo, pero nadie queda sin hablar.
- **Se proyecta la matriz real**, no una versión simplificada.
- Las diapositivas se entregan junto con los documentos.
- Al final hay preguntas del profesor, **dirigidas a integrantes específicos**.

Las preguntas son individuales. Un equipo donde solo una persona puede explicar el diseño no trabajó en equipo —y eso se refleja en este rubro. **Repartir el trabajo es correcto; repartir el entendimiento no.**

10 Formato y entrega

Los cinco documentos se redactan en LaTeX y se entregan en **dos formatos: la fuente `.tex` y el `.pdf` compilado**. La única excepción es la presentación de la defensa, que puede hacerse con la herramienta que prefieran y se entrega solo en PDF.

Nombre del archivo	Formatos	Contenido
`P1_Politicas_grupoX`	.tex + .pdf	Informe de políticas de seguridad

`P1_ControlAcceso_grupoX`	.tex + .pdf	Modelo de acceso, HBAC y separación de responsabilidades
`P1_Matriz_grupoX`	.tex + .pdf	La matriz de control de acceso
`P1_Arquitectura_grupoX`	.tex + .pdf	Componentes, tecnologías y decisiones
`P1_AtributoDI_grupoX`	.tex + .pdf	Respuestas a los indicadores DI1–DI4
`P1_Presentacion_grupoX`	.pdf	Diapositivas de la defensa

Portada en cada documento con integrantes y carné, número de grupo, curso y fecha. Referencias en **formato APA**. Entrega por la plataforma del curso, **jueves 15 de octubre antes de la clase**.

11 Evaluación

Cada criterio se califica en cuatro niveles. La nota del proyecto es la suma ponderada.

Criterio	Peso	Excelente (90–100)	Bueno (70–89)	Básico (50–69)	Deficiente (<50)
Políticas de seguridad *Activos, tríada, amenazas, marco legal.*	18 %	Políticas específicas del cliente; amenazas con al menos una interna; marco legal pertinente al giro.	Completas, con alguna sección genérica o marco legal superficial.	Genéricas: servirían para cualquier empresa. Sin amenaza interna.	Ausentes o sin relación con el cliente.
Modelo de control de acceso *DAC, MAC, RBAC o ABAC.*	15 %	Elección explícita; los otros tres descartados con razones ligadas al caso; nivel de RBAC definido si aplica.	Elegido y justificado, pero alguna alternativa descartada en abstracto.	Nombra un modelo sin comparar con los otros.	No define modelo o lo contradice en la matriz.
Controles de historial (HBAC) *Tipo, riesgo, datos, decisión.*	10 %	Dos o más controles de tipos distintos, cada uno con riesgo, datos requeridos y falsos positivos previstos.	Controles definidos, con algún elemento sin especificar.	Mencionados sin tipo ni riesgo asociado.	Ausentes y sin justificación de por qué no.
Separación de responsabilidades *Técnica, alternativas, aplicación.*	15 %	Técnica nombrada y justificada; alternativas descartadas; **visible en la matriz**; fricción reconocida.	Aplicada, pero sin declarar la fricción o sin comparar alternativas.	Nombrada pero no aplicada: no cambia ninguna celda.	Ausente.
Matriz de control de acceso *Completitud y celdas condicionadas.*	14 %	Completa y sin ambigüedad; tres o más celdas condicionadas con regla verificable; mínimo privilegio justificado.	Completa, con alguna condición poco precisa.	Celdas vacías o ambiguas; menos de tres condicionadas.	Ausente o ilegible.
Arquitectura del sistema *Componentes, tecnologías, decisiones.*	14 %	Componentes y fronteras claros; cada tecnología justificada **desde la seguridad**; riesgos residuales declarados.	Arquitectura clara, con alguna tecnología sin argumento de seguridad.	Lista de tecnologías sin justificación; fronteras no definidas.	Ausente.

Criterio	Peso	Excelente (90–100)	Bueno (70–89)	Básico (50–69)	Deficiente (<50)
Atributo Diseño (DI) *Respuestas a DI1–DI4.*	5 %	Los cuatro indicadores respondidos con ejemplos concretos del proyecto y evidencia señalada en los otros entregables.	Respondidos, con algún indicador genérico o sin apuntar a evidencia.	Respuestas vagas que repiten los otros documentos sin señalar dónde está la evidencia.	Ausente o sin relación con el proyecto.
Defensa oral *Cobertura y dominio individual.*	9 %	Las siete etapas cubiertas en tiempo; todos participan; responden con precisión a preguntas individuales.	Buena cobertura, con algún integrante inseguro.	Etapas sin cubrir o una sola persona domina el contenido.	No se presenta o no responden.
Total	**100 %**				

12 Trabajo en grupo

- El proyecto se resuelve **en grupos de 4 a 5**. Organizarse es parte del ejercicio.
- **Roten el conocimiento.** Quien no escribió las políticas igual va a tener que defenderlas.